

X.509 PQC 전환을 위한 하이브리드 서명 전략 비교 분석

이민우* 심민주* 조수빈** 형유림** 서화정***

*한성대학교 정보컴퓨터공학과(대학원생)

**한성대학교 융합보안학과(학부생)

***한성대학교 융합보안학과(부교수)

Comparative Analysis of Hybrid Signature Strategies for X.509 Post-Quantum Transition

Min-Woo Lee* Min-Joo Sim* Su-Been Cho** Yu-Lim Hyoung**
Hwa-Jeong Seo***

*Hansung University(Graduate student)

**Hansung University(Undergraduate student)

***Hansung University(Associate Professor)

요약

TLS 1.3에서 X.509 인증서의 공개키 및 서명 체계를 ECDSA에서 ML-DSA로 전환하면 인증서 크기가 약 14.6배 증가한다. 이 문제를 완화하기 위해 하이브리드 인증서(Catalyst, Composite, Chameleon)와 signature combiner(Naive Combiner, Compact Combiner)가 제안되었으나, 두 접근법을 같은 기준으로 비교한 연구는 아직 이루어지지 않았다. 본 논문에서는 크기, 핸드셰이크 바이트, 검증 시간, 호환성의 4가지 축으로 구성된 전환 비용 모델을 제안하고, 5가지 전환 방식을 비교한다. 서버팜·모바일·IoT 환경에 대한 분석 결과, 레거시 호환이 중요한 환경에서는 Catalyst가, IoT에서는 combiner 계열이 근소하게 우세한 것으로 나타났다. 5가지 방식의 크기 차이는 4.4% 이내로 측정되었다.

I. 서론

NIST는 2024년 격자 기반 전자서명 ML-DSA(FIPS 204)[1]를 표준화하였고, 이에 따라 TLS 1.3의 X.509 인증서에서 사용하는 공개키 및 서명 체계를 양자내성암호(Post-Quantum Cryptography, PQC)로 전환하는 작업이 진행되고 있다. ML-DSA-65의 공개키는 1,952 B, 서명값은 3,309 B로 ECDSA P-256(각 64 B, 72 B)에 비해 약 30배, 46배 크다. 인증서 DER(Distinguished Encoding Rules) 크기로 보면 377 B에서 5,507 B로 14.6배 증가하며, 모바일·IoT처럼 대역폭이 제한된 환경에서는 핸드셰이크 지연이 발생할 수 있다.

따라서 기존 알고리즘과의 공존이 필요한 전환 기에는 암호 민첩성(crypto agility)[2]을 어떻게 확보할 것인지가 핵심 과제가 된다.

과도기 접근법은 크게 두 갈래로 나뉜다. 하나는 X.509 포맷 자체를 수정하는 하이브리드 인증서(Catalyst[3], Composite[4], Chameleon[5])이고, 다른 하나는 기존 포맷을 유지하면서 서명만 결합하는 signature combiner(Naive Combiner, Compact Combiner[6])이다. 하지만 이 두 그룹을 같은 기준으로 비교한 연구는 아직 이루어지지 않았다. Chen[7]은 하이브리드 인증서 3종만 비교하였고, Janneck은 combiner의 보안 증명에 집중하였으며, Sim et al.[8]은

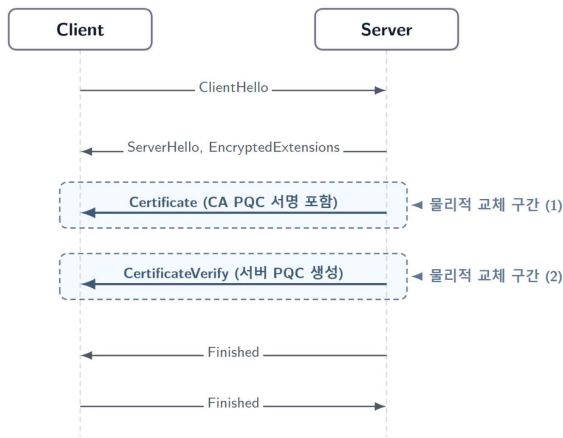
KpqC의 TLS 벤치마크를 다루었으나 전환 방식 간 비교와는 관점이 다르다.

본 논문에서는 크기·핸드셰이크 바이트·검증 시간·호환성의 4가지 축으로 전환 비용 모델을 구성하고, 하이브리드 인증서 3종과 combiner 2종을 함께 비교한다. 서버팜·모바일·IoT 환경별로 적합한 방식을 도출하고, 크기가 아닌 호환성과 보안 모델이 핵심 선택 기준이 됨을 보인다.

II. 배경 지식

2.1 TLS 1.3에서의 서명 구조

TLS 1.3[9] 핸드셰이크에서 전자서명은 두 곳에 사용된다.



[그림 1] TLS 1.3의 X.509 PQC 전환 지점

하나는 인증기관(Certificate Authority, CA)이 인증서를 발급할 때 포함하는 서명이고, 다른 하나는 서버가 핸드셰이크 도중 생성하는 CertificateVerify 서명이다. 체인 길이가 2인 구성에서 클라이언트는 총 3회 서명 검증을 수행하게 되며, PQC 전환 시 이 모두가 교체 대상이 된다[10].

2.2 전환 방식

Catalyst는 PQ 데이터를 non-critical extension으로 추가하는 방식이다. 레거시 클라이언트는 이 확장을 무시하고 기존 서명만으로 검증할 수 있어 하위 호환성이 우수하다. Composite는 클래식 서명과 PQ 서명을 하나의

OID로 묶고, 둘 다 유효해야 검증을 통과하는 AND 모델을 적용한다. 두 알고리즘을 모두 검증하는 보수적인 모델이지만, 레거시 호환이 불가능하다. Chameleon은 Base 인증서 안에 Delta 인증서를 내장하는 구조로, 전환 완료 후 Delta를 독립 인증서로 분리하여 사용할 수 있다.

Signature combiner 중 Naive Combiner는 두 서명을 단순 연결하는 방식으로, 구현이 간단하지만 strong unforgeability(SUF)를 보존하지 못한다. 이는 기존 서명 쌍으로부터 같은 메시지에 대한 다른 유효 서명을 만들 수 있는 가능성이 남는다는 의미이다. Compact Combiner는 EdDSA의 Fiat-Shamir 구조를 활용하여 commitment 32 B를 생략하면서도 SUF를 보존한다. 다만 EdDSA 기반에서만 적용 가능하며, ECDSA에는 사용할 수 없다.

III. 전환 모델 및 비교 분석

3.1 전환 비용 평가 모델

본 논문에서는 4가지 축으로 구성된 전환 비용 모델을 제안한다. C_size 는 인증서 DER 크기, C_hs 는 체인 전송량과 서명 크기를 반영한 핸드셰이크 비용, C_verify 는 체인 전체 검증 시간(μs), C_compat 는 레거시 호환 여부를 0~1 사이 점수로 나타낸 것이다(0에 가까울수록 호환성이 우수). 각 축을 정규화한 뒤 환경별 가중치를 적용하여 총 비용을 $C_{total}(S, E) = w_1 \cdot \hat{C}_{size} + w_2 \cdot \hat{C}_{hs} + w_3 \cdot \hat{C}_{verify} + w_4 \cdot C_{compat}$ 를 산출하며, C_{total} 이 낮을수록 해당 방식이 유리하다.

가중치는 환경에 따라 다르게 설정하였다. 서버팜은 (0.10, 0.20, 0.20, 0.50), 모바일은 (0.20, 0.30, 0.20, 0.30), IoT는 (0.35, 0.20, 0.35, 0.10)이다. 서버팜은 다양한 클라이언트를 수용해야 하므로 호환성($w_4 = 0.5$) 비중이 가장 높고, 모바일은 핸드셰이크 지연이 사용자 경험에 직접 영향을 미쳐 C_hs 비중이 높다. IoT는 양쪽 펌웨어를 직접 관리할 수 있어 호환성 비중이 가장 낮다.

C_compat 점수는 주요 TLS 라이브러리

(OpenSSL, BoringSSL, GnuTLS, NSS)의 지원 현황과 fallback 가능 여부를 기준으로 산정하였다. 서버팜 기준으로 Catalyst 0.1, Chameleon 0.2, Composite 0.7, Naive/Compact Combiner 0.8이며, 모바일과 IoT에서는 환경 특성에 따라 차등 조정하였다.

3.2 실험 환경 및 비교 대상

실험은 OQS Docker 환경 (openquantumsafe/oqs-openssl3)에서 수행하였다 [11]. liboqs 0.11.0과 oqsprovider를 OpenSSL 3.6.0에 연동하였고, 서명 성능은 openssl speed로 3초간 측정하였다. 본 논문에서 제시되는 인증서 및 파라미터 크기는 모두 ASN.1/DER 인코딩을 포함한 값이다.

5가지 방식 모두 ML-DSA-65 기반이다. Catalyst와 Composite는 직접 측정하였고, Chameleon은 ASN.1 구조를 분석하여, combiner 2종은 구성 요소의 측정값을 합산하여 각각 추정하였다. 추정 모델의 정확도는 동일한 합산 방법을 Composite에 적용하여 검증하였으며, 추정값과 실측값의 오차는 0.6%였다. Compact Combiner는 Bird of Prey의 명세에 따라 Ed25519 commitment 32 B 생략을 반영하여 산출하였다.

Composite는 oqsprovider의 p384_mldsa65를 사용하였다. ECDSA P-384는 P-256에 비해 크기 차이(약 30 B)는 작지만, 검증 속도(385.7 μ s vs 38.1 μ s)가 약 10배 느려 검증 시간에 상당한 영향을 미친다. Composite I-D에는 P-256 기반 조합도 정의되어 있으며, 본 논문에서는 해당 조합의 검증 시간을 구성 요소의 측정값으로부터 추정하여 3.4절에서 함께 제시한다.

3.3 인증서 크기 비교

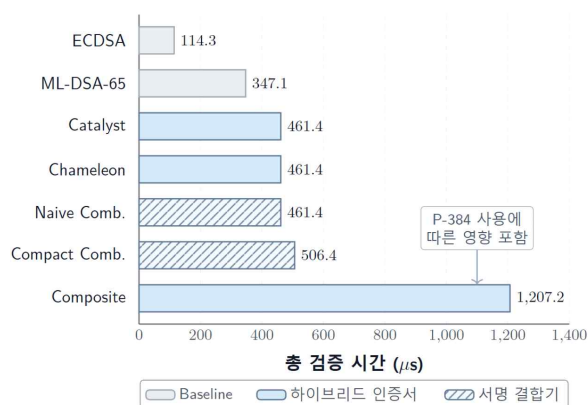
[표 1]은 ML-DSA-65 기준 각 방식의 인증서 DER 크기이다. Catalyst·Chameleon·Naive Combiner는 classical 측에 ECDSA P-256을, Composite는 ECDSA P-384를, Compact Combiner는 Ed25519를 사용하였다.

방식	Cert(B)	vs ECDSA
ECDSA P-256	377	1.0x
ML-DSA-65	5,507	14.6x
Compact Comb	5,579	14.8x
Naive Comb	5,660	15.0x
Composite	5,706	15.1x
Catalyst	5,749	15.2x
Chameleon	5,823	15.4x

[표 1] 전환 방식별 인증서 크기
5가지 방식의 크기는 5,579~5,823 B 범위이고, 최대 차이는 244 B(4.4%)에 불과하다. ML-DSA-65의 DER 인코딩된 공개키(1,974 B)와 서명(3,309 B)이 전체 크기의 대부분을 차지하기 때문에 방식 간 차이가 크지 않다. Compact Combiner(5,579 B)가 가장 작는데, Ed25519의 작은 공개키와 commitment 생략이 함께 작용한 결과이다. Chameleon(5,823 B)은 Delta 구조의 오버헤드로 인해 가장 크다.

3.4 서명 검증 시간 비교

체인 길이 2 기준으로 3회 검증(CA 서명 2회 + CertificateVerify 1회)을 수행한다. 모든 방식에서 CertificateVerify도 클래식+PQ 양쪽 서명을 포함한다고 가정하였다. 다만 실제 배포시 Catalyst·Chameleon은 ECDSA만으로 CertificateVerify를 수행할 수 있으므로, 실제 검증 시간은 여기 제시된 값보다 짧아질 수 있다.



[그림 2] 핸드셰이크 검증 시간

1회 검증 시간은 Catalyst·Chameleon·Naive Combiner가 ECDSA P-256(38.1 μ s) + ML-DSA-65(115.7 μ s) = 153.8 μ s이고,

순위	서버팜	모바일	IoT
1	Catalyst 0.465	Catalyst 0.702	Naive C. 0.682
2	Chameleon 0.520	Chameleon 0.740	Catalyst 0.692
3	Naive C. 0.810	Naive C. 0.933	Compact C. 0.694
4	Compact C. 0.816	Compact C. 0.936	Chameleon 0.700
5	Composite 0.963	Composite 1.108	Composite 1.047

[표 2] 전환 방식별 인증서 크기

Compact Combiner는 $\text{Ed25519}(53.1 \mu\text{s}) + \text{ML-DSA-65}(115.7 \mu\text{s}) = 168.8 \mu\text{s}$ 이다.

[그림 2]는 이 결과를 그래프로 나타낸 것이다. Composite(ECDSA P-384)는 $1,207.2 \mu\text{s}$ 로 가장 느리지만, 이는 ECDSA P-384 자체의 검증 시간($385.7 \mu\text{s}$)에 기인한다. 측정값(1회 $402.4 \mu\text{s}$)이 단순 합산 예상($501.4 \mu\text{s}$)보다 낮은 것은 oqsprovider 내부의 최적화 또는 openssl speed의 벤치마크 특성에 의한 것으로 판단된다. ECDSA P-256을 사용할 수 있다면 $461.4 \mu\text{s}$ 로 다른 방식과 동등한 수준이 된다. 한편 ML-DSA-65 단독($347.1 \mu\text{s}$)은 ECDSA($114.3 \mu\text{s}$)의 3.0배로, 서명 크기가 46배 증가한 것에 비해 검증 속도 저하는 상대적으로 완만한 편이다.

3.5 환경별 적합성 분석

서버팜·모바일에서는 Catalyst가 1위이다. 호환성 가중치가 높은 환경에서는 레거시 fallback 지원 여부가 결정적인 차이를 만든다. Chameleon은 비슷한 호환 특성을 가지면서 전환 완료 후 Delta를 분리할 수 있다는 점에서 2위를 차지하였다.

IoT에서는 호환성 가중치(0.1)가 낮아지면서 Naive Combiner(0.682)가 1위가 된다. 다만 1~4위가 0.018 이내로 매우 가까워, 디바이스의 구체적인 제약에 따라 유연하게 선택할 수 있다.

Composite는 ECDSA P-384 기준으로 모든 환경에서 최하위이지만, ECDSA P-256 추정을 적용하면 C_verify가 다른 방식과 동등해져 호환성만이 순위를 결정하는 요인으로 남게 된다. 이 경우 서버팜에서 Composite의 C_total은 약 0.50으로, Catalyst(0.465)와 Chameleon(0.520)사이인 2~3위권에 위치한다. Composite의 AND 모델은 두 알고리즘을 모두 검증하는 보수적인

접근이므로, oqsprovider에서 P-256 기반 Composite의 실측이 가능해지면 높은 보안이 요구되는 환경에서 충분히 경쟁력을 갖출 수 있다.

가중치를 ± 0.1 범위에서 변동시킨 민감도 분석에서도 세 환경 모두 1위는 유지되었다. 서버팜에서 Catalyst의 변동폭(0.052)은 2위와의 격차(0.055)보다 작아 순위가 뒤집히지 않았다.

IV. 결론

본 논문에서는 X.509 인증서의 공개키 및 서명 체계의 PQC 전환 비용을 평가하기 위한 4축 모델을 제안하고, 하이브리드 인증서 3종과 combiner 2종을 함께 비교하였다. 5가지 방식의 크기 차이는 4.4% 이내에 머물러, 방식 선택에서는 호환성과 보안 모델이 핵심 기준이 된다. 서버팜·모바일에서는 Catalyst가, IoT에서는 combiner 계열이 근소하게 우세하였고, Composite는 ECDSA P-256 조합의 실측이 이루어지면 2~3위권으로 상승할 여지가 있다.

향후 연구에서는 본 논문에서 추정으로 다룬 Chameleon·combiner의 실측 검증과 ECDSA P-256 기반 Composite 측정을 수행하고, KpqC 알고리즘(HAETAE, AIMer 등)으로의 확장을 계획하고 있다.

[참고문헌]

- [1] NIST, FIPS 204: Module-Lattice-Based Digital Signature Standard (ML-DSA). Available online: <https://csrc.nist.gov/pubs/fips/204/final> (accessed on 5 April 2026)
- [2] N. Bindel, U. Herath, M. McKague, and

- D. Stebila, "Transitioning to a Quantum-Resistant Public Key Infrastructure," Proceedings of the International Conference on Post-Quantum Cryptography (PQCrypto), pp.384-405, 2017.
- [3] ITU-T, X.509: Public-key and attribute certificate frameworks, 2019.
- [4] M. Ounsworth, J. Gray, M. Pala, and J. Klaußner, "Composite ML-DSA for use in X.509 Public Key Infrastructure," IETF Internet-Draft, draft-ietf-lamps-pq-composite-sigs-16, 2026.
- [5] C. Bonnell, J. Gray, D. Hook, T. Okubo, and M. Ounsworth, "A Mechanism for Encoding Differences in Paired Certificates," IETF Internet-Draft, draft-bonnell-lamps-chameleon-certs-07, 2025.
- [6] J. Janneck, "Bird of Prey: Practical Signature Combiners Preserving Strong Unforgeability," Cryptology ePrint Archive, Report 2025/1844, 2025.
- [7] A. C. H. Chen, "A Comparative Study of Hybrid Post-Quantum Cryptographic X.509 Certificate Schemes," arXiv:2511.00111, 2025.
- [8] M. Sim, G. Song, S. Eum, M. Lee, S. Yoon, A. Baksi, and H. Seo, "Integrating and Benchmarking KpqC in TLS/X.509," Electronics, Vol.14, No.18, pp.3717, 2025.
- [9] E. Rescorla, "The Transport Layer Security (TLS) Protocol Version 1.3," RFC 8446, 2018.
- [10] P. Kampanakis, P. Panburana, E. Daw, and D. Van Geest, "The Viability of Post-Quantum X.509 Certificates," Cryptology ePrint Archive, Report 2018/063, 2018.
- [11] Open Quantum Safe Project. Available online: <https://openquantumsafe.org> (accessed on 5 April 2026)